Individual Testing

1. Assignment & Accountability

Contributor / Member ID	Rola
Type of vulnerable	[CSRF (Cross-Site Request Forgery)]
Week / reporting period	Week 1 / 24 Oct 2026
Target / environment	Juice Shop (OWASP Juice Shop, localhost:3000)

2. Objective, Scope & Preconditions

Security question: Can the authenticated password-change function be triggered or completed without a genuine, user-confirmed current-password check — i.e. is the request protected against Cross-Site Request Forgery (CSRF), and does it properly re-verify the user's current password server-side? In-scope asset: /rest/user/change-password on the local OWASP Juice Shop instance (http://localhost:3000). Account/role used: a self-registered, low-privilege customer account. Prerequisites: a valid session token for the test account obtained via normal login; Burp Suite Repeater to intercept and replay/modify the request. Exclusions: no CSRF proof-of-concept page was hosted against a real third-party victim; the forgeability of the request was assessed by request structure (method, token requirements, parameters) rather than by executing a live cross-site attack against another person.

3. Test Log

Date	Asset / Endpoint	Test case	Outcome	Evidence ID
2026-10-24	/rest/user/change-password	Resend intercepted change-password request with the current-password value removed	HTTP 200 — password changed successfully with no current-password verification	EVID-001
2026-10-24	/rest/user/change-password	Inspect request method and headers for an anti-CSRF token	Request is a plain GET with no CSRF token parameter or header present	EVID-002
2026-10-24	/rest/user/change-password	Log in with the newly set password to confirm the change was persisted	Login succeeds with the new password, confirming the unverified change was applied server-side	EVID-003

4. Finding Record (duplicate this section for each suspected/confirmed finding)

Finding ID / Title	CSRF-01 — Cross-Site Request Forgery / Missing Current-Password Verification on /rest/user/change-password
Affected asset	/rest/user/change-password (Change Password function), OWASP Juice Shop
Method / account role	GET request, authenticated as a low-privilege customer account
Severity / CVSS	High — CVSS 3.1 Base Score ≈ 8.0 (AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:H/A:N)

4.1 Summary

The change-password function (/rest/user/change-password) accepts a GET request with the new password supplied as a URL query parameter, and the "Change" action is only disabled client-side (via a disabled button attribute) when the Current Password field is unfilled. By removing the current-password value from the intercepted request and resending it, the password was changed successfully without the server independently verifying the account's actual current password. Because the sensitive action is a simple GET request with no anti-CSRF token and no server-side current-password confirmation, it is also structurally vulnerable to Cross-Site Request Forgery: a malicious page could trigger the same request (e.g. via an auto-submitting image or link) using the victim's existing session, silently changing their password.

4.2 Preconditions

A registered, authenticated customer account with a valid session token/cookie (no special role required). The victim must have an active, authenticated session in their browser at the time the forged request is triggered. No special server configuration is required; this reflects the application's default behavior.

4.3 Reproduction Steps

1. Log in as the test account and navigate to the Change Password page; intercept the resulting request in Burp Suite.
2. In Burp Suite Repeater, confirm the request is a GET to /rest/user/change-password carrying current, new, and repeat password values as query parameters, with no CSRF token present.
3. Remove the current-password parameter (or substitute an incorrect value) from the request and resend it with the same session token.

4.4 Expected vs. Actual Result

Expected: The server should reject the request with an error unless the correct current password is supplied, and the endpoint should require a valid, per-session anti-CSRF token on top of the session cookie/JWT so that the request cannot be forged from another site.
Actual: The password was changed successfully even with the current-password value removed from the request, and the request required no CSRF token — only the session credential, which a forged cross-site request would also carry automatically.

4.5 Impact & Limitations

Demonstrated impact: an attacker who can get a logged-in victim to load a crafted page or link can change that victim's account password without their knowledge or consent, leading to full account takeover. Affected roles/data: any authenticated customer account. Conditions: the victim must have an active session at the time the forged request runs; modern browser SameSite cookie defaults may reduce exploitability depending on how the session token is stored (cookie vs. client-side JWT), which was not separately verified. What was not proven: a live, hosted cross-site exploit against a separate victim browser was not executed in this engagement; only the request-level absence of CSRF protection and current-password verification was confirmed.

4.6 Remediation Recommendation

Require the user's correct current password to be re-verified server-side (not just client-side) before any password change is applied. Change the endpoint to use a state-changing HTTP method (POST/PUT) rather than GET, since GET requests are trivially triggerable cross-site. Implement a per-session anti-CSRF token (e.g. synchronizer token pattern) validated on every state-changing request, and/or set the session cookie's SameSite attribute to Strict or Lax. As defense in depth, send a confirmation email/notification whenever a password is changed, and consider re-authentication (step-up auth) for sensitive account actions.

5. Evidence Register

Filename / location	Related finding	Sensitive data redacted?
csrf_changepw_request_no_token.png	CSRF-01	No — lab data only, self-owned test account
csrf_changepw_success_response.png	CSRF-01	No — lab data only, self-owned test account